

Executive GRC Compliance Report

Organisation: Acme Corporation

Report Date : 28 June 2026

1. Executive Summary

Acme Corporation's current compliance posture scores 35.8%, which is classified as critically deficient against ISO 27001:2022 and SOC 2 Type II benchmarks. The automated scan identified 30 open findings across 10 assets, of which 10 are rated Critical and 10 High severity. Estimated financial exposure from unmitigated risk stands at USD 2,440,000. Immediate remediation of Critical findings is mandatory to reduce inherent risk scores and achieve sustained compliance. This report presents a prioritised remediation roadmap aligned to the applicable control frameworks.

2. Compliance Readiness Score

35.8%

Overall Compliance Posture: AT RISK

3. Key Risk Metrics

TOTAL FINDINGS
30

CRITICAL SEVERITY
10

HIGH SEVERITY
10

ASSETS AFFECTED
10

FINANCIAL EXPOSURE (USD)
\$2,440,000

CONTROL DOMAINS BREACHED
4

4. Critical & High Severity Findings

Asset ID	Asset Name	Vulnerability	Severity	Control Mapping
ASSET-100	db-server-02	Default Credentials Exposed	Critical	SOC 2 CC6.1 / ISO 27001 A.8.20 - Acces...
ASSET-101	auth-service-04	Brute Force Attack Surface	High	SOC 2 CC6.1 / ISO 27001 A.8.20 - Acces...
ASSET-102	db-server-02	SSL 2.0 Deprecated Protocol	Critical	ISO 27001 A.8.24 / SOC 2 CC6.3 - Crypt...
ASSET-103	auth-service-04	TLS 1.0 Enabled	High	ISO 27001 A.8.24 / SOC 2 CC6.3 - Crypt...
ASSET-104	backup-server-09	Unencrypted HTTP Traffic	High	ISO 27001 A.8.24 / SOC 2 CC6.3 - Crypt...
ASSET-105	hr-portal-07	Outdated OpenSSL (RCE vector)	Critical	ISO 27001 A.8.24 / SOC 2 CC6.3 - Crypt...
ASSET-106	web-prod-01	Missing OS Patch - MS17-010	Critical	ISO 27001 A.8.19 - Technical Vulnerabi...
ASSET-108	db-server-02	Open Port 23 (Telnet)	High	ISO 27001 A.8.20 - Network Security
ASSET-109	vpn-endpoint-06	SSH Root Login Permitted	High	ISO 27001 A.8.20 - Network Security
ASSET-111	db-server-02	Authentication Bypass Possible	Critical	SOC 2 CC6.1 / ISO 27001 A.8.20 - Acces...
ASSET-112	vpn-endpoint-06	RCE via PHP Deserialization	Critical	ISO 27001 A.8.19 - Technical Vulnerabi...
ASSET-113	auth-service-04	Open Port 3389 - No MFA	High	ISO 27001 A.8.20 - Network Security
ASSET-116	db-server-02	Patch Missing - Log4Shell	Critical	ISO 27001 A.8.19 - Technical Vulnerabi...
ASSET-118	auth-service-04	Brute Force on Admin Panel	High	SOC 2 CC6.1 / ISO 27001 A.8.20 - Acces...
ASSET-119	auth-service-04	Unencrypted Database Connection	Critical	ISO 27001 A.8.24 / SOC 2 CC6.3 - Crypt...
ASSET-120	mail-server-05	Old Version PHP 5.6	High	ISO 27001 A.8.19 - Technical Vulnerabi...
ASSET-122	ci-cd-pipeline-08	SSL Certificate Expired	High	ISO 27001 A.8.24 / SOC 2 CC6.3 - Crypt...
ASSET-123	backup-server-09	Missing Authentication on API	Critical	SOC 2 CC6.1 / ISO 27001 A.8.20 - Acces...
ASSET-125	backup-server-09	Telnet Service Active	High	ISO 27001 A.8.20 - Network Security
ASSET-128	ci-cd-pipeline-08	RCE via Shell Injection	Critical	ISO 27001 A.8.19 - Technical Vulnerabi...

5. Control Gap Analysis

SOC 2 CC6.1 / ISO 27001 A.8.20 (8 findings)

Logical and physical access controls, authentication policy, and user provisioning.

ISO 27001 A.8.24 / SOC 2 CC6.3 (8 findings)

Encryption in transit and at rest, certificate lifecycle, cipher suite management.

ISO 27001 A.8.19 (8 findings)

Patch management, software lifecycle, version control, and exploit mitigation.

ISO 27001 A.8.20 (6 findings)

Network segmentation, firewall rules, open port policy, and insecure protocol removal.

6. Prioritised Remediation Action Plan

P1 - IMMEDIATE (0-14 days)

Rotate all default credentials and enforce MFA on all externally facing services. Disable Telnet (port 23) and enforce SSH key-based authentication only. Apply emergency patches for all Critical CVEs (Log4Shell, MS17-010, and RCE vectors).

P2 - SHORT-TERM (15-45 days)

Upgrade TLS to 1.3 on all endpoints and disable deprecated cipher suites. Replace all cleartext protocols (FTP, HTTP, SMTP AUTH)

with encrypted equivalents. Conduct a full port audit; close all non-business-essential open ports.

P3 - MEDIUM-TERM (46-90 days)

Establish a vulnerability management lifecycle with automated scanning cadence. Integrate vulnerability feeds with ITSM ticketing for SLA-driven remediation. Conduct tabletop exercises for scenarios aligned to the Critical findings above.

P4 - GOVERNANCE (90-180 days)

Formalise an ISO 27001:2022 ISMS scope and complete Statement of Applicability (SoA). Commission an external SOC 2 Type II readiness assessment. Schedule quarterly GRC dashboard reviews at executive and board level.

DISCLAIMER: This report is generated automatically by the Enterprise GRC Automation Dashboard. It is intended for internal risk management purposes only and does not constitute legal, audit, or certification advice. Results should be reviewed by a qualified GRC professional before use in formal compliance submissions.